

Hacking Ético: Information Gathering

El arte de comprometer un sistema antes de enviar un solo paquete.

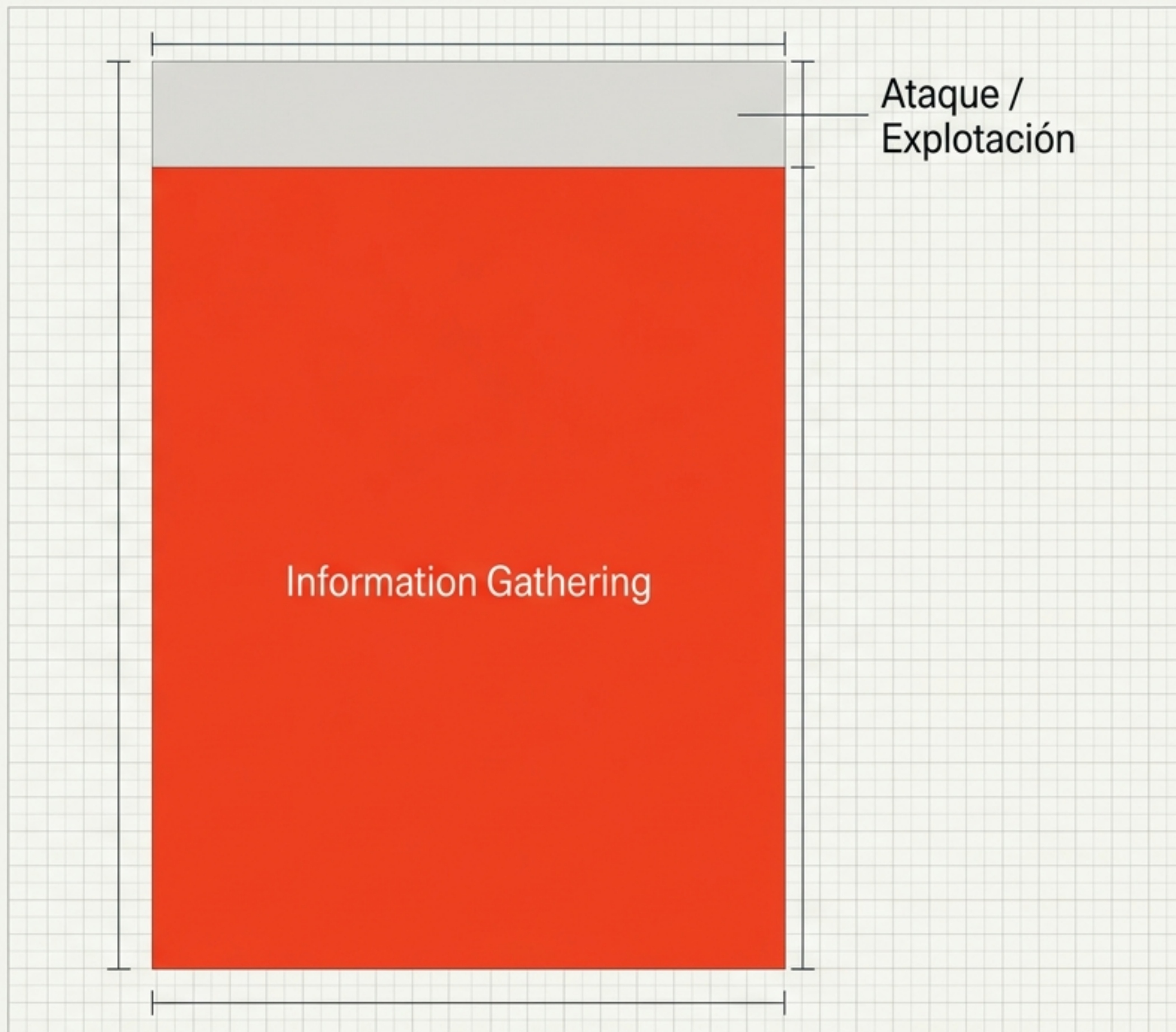
Presentado por Carlos Noboa



El 90% del éxito reside en la observación.

En un escenario real, un atacante emplea el 90% de su tiempo elaborando un perfil perfecto de su objetivo a través del análisis de datos.

Solo un 10% del tiempo se invierte en lanzar y ejecutar el ataque activo. La batalla se gana en la fase de reconocimiento.



La Fase Cero: Inteligencia en Fuentes Abiertas (OSINT)

Es la primera fase metodológica de toda **auditoría de seguridad** o **proceso de pentesting**.

Conjunto de técnicas de hacking que buscan recabar la máxima cantidad de información de **fuentes abiertas y públicas**.

Construir el perfil tecnológico y estructural de la entidad o persona objetivo sin interactuar de forma intrusiva con sus servidores internos.

Escaneo

Explotación

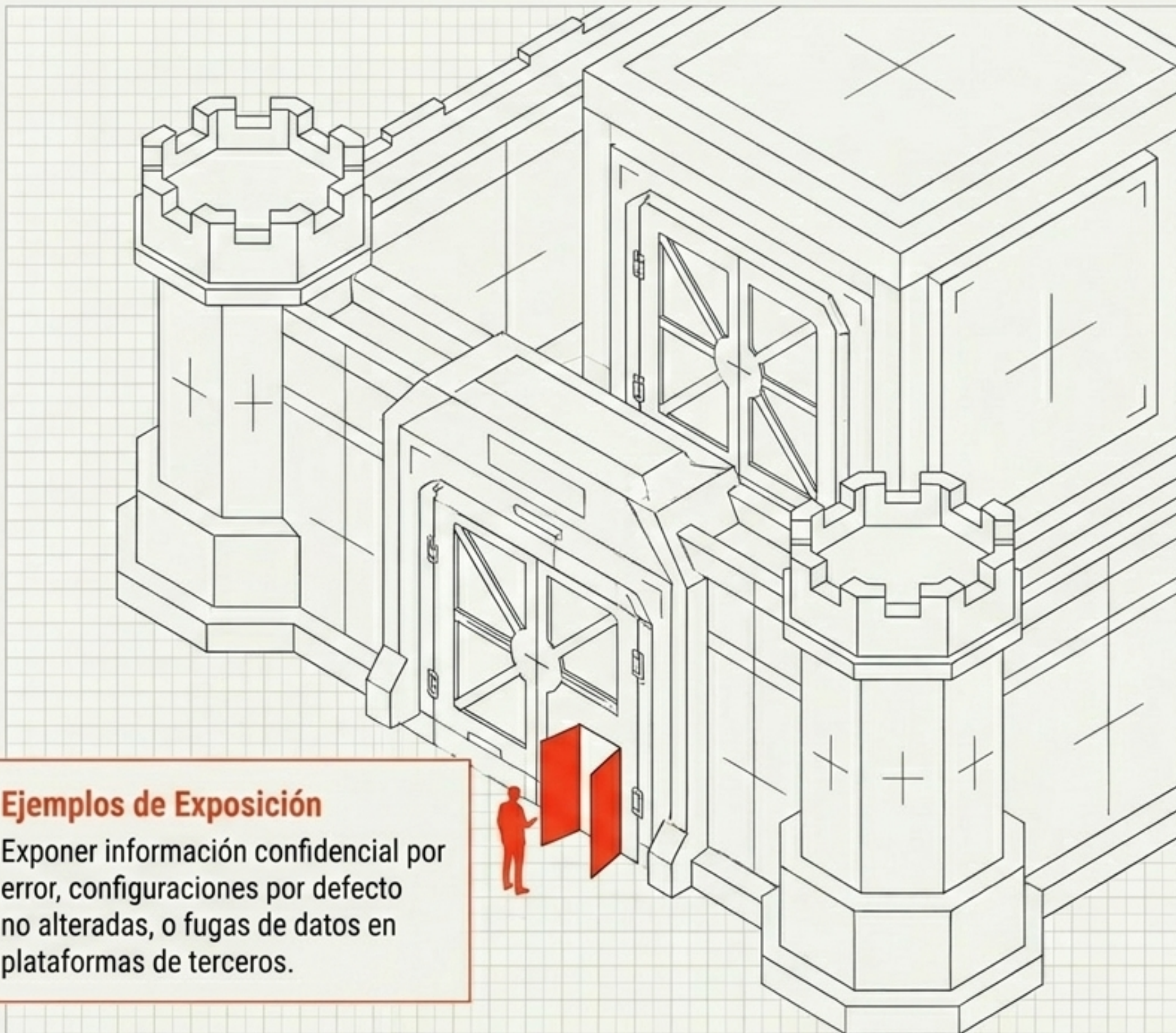
La tecnología no puede parchear el error humano.

Entidades auditadas con niveles altísimos de ciberseguridad perimetral presentan frecuentemente fallos críticos durante esta fase temprana.

Las deficiencias y vulnerabilidades detectadas en OSINT derivan directamente del factor humano.

Ejemplos de Exposición

Exponer información confidencial por error, configuraciones por defecto no alteradas, o fugas de datos en plataformas de terceros.



¿Qué estamos buscando? Mapeo del Perfil Tecnológico



Derivado de estas vulnerabilidades perimetrales, a menudo es posible vislumbrar la estructura interna (medidas internas e información del entorno físico).

Pilar 1: Mapeando la Infraestructura y Redes



Whois & Ripe

Propiedad del dominio, contacto administrativo y rangos IP.

Estado actual: En declive, por motivos de privacidad los datos de contacto ya no se exponen masivamente.



Host / Nslookup

Resolución DNS que traduce nombres de dominio a direcciones IP (CLI o entornos Windows).



Transferencia de Zona (axfr)

Replicación de bases de datos DNS. Debería permitirse únicamente desde otros DNS.

Peligro: Una mala configuración expone IPs privadas y equipos internos.

```
dig axfr @ns1.dominio.net  
dominio.net
```


Pilar 2: Indexación, Rastreadores y Google Hacking

Los buscadores (mediante rastreadores como Googlebot) son herramientas de indexación extremadamente eficaces de páginas de dominio público.

Google Hacking: Técnica que utiliza filtros y operadores lógicos para extraer información confidencial indexada por error. La evaluación se realiza de izquierda a derecha.

La Ironía de robots.txt

Un archivo diseñado para indicar qué NO indexar funciona frecuentemente como un mapa del tesoro, revelando las rutas más sensibles.

```
User-agent: Googlebot
Disallow: /nogooglebot/
```

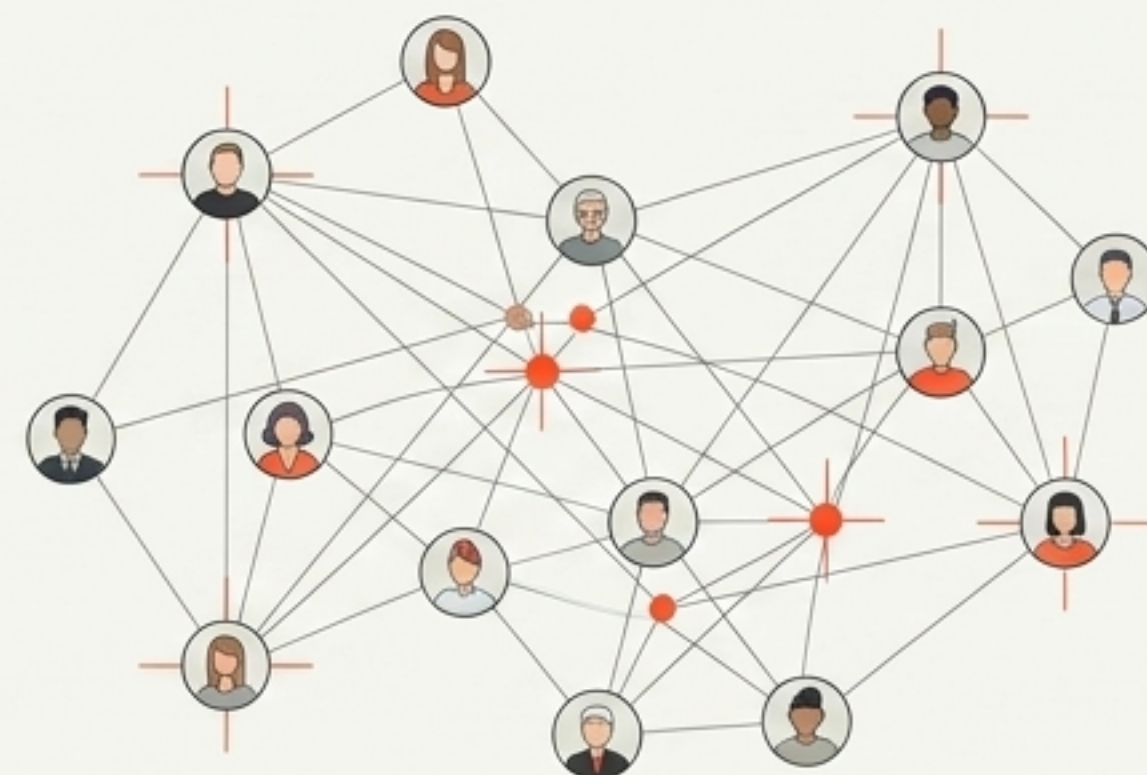
```
User-agent: *
Allow: /
```

Sitemap: <http://www.example.com/sitemap.xml>



Pilar 3: Fugas de Datos e Ingeniería Social

██████	john.doe@email.com:password123
██████	john.doe@email.com:password123
██████	john.doe@email.com:password123
██████	john.doe@email.com:password123
██████	admin@company.com:AdminPass#
██████	admin@company.com:AdminPass#
██████	databases mmoreseary dumps
██████	admin@company.com##
██████	admin@company.com@company.com:password23
██████	datop dump: john.doe@empanty.com:password12
██████	database dump1: dtabase
██████	evalued@email.com



Fugas en Texto Plano (Pastebin):

Aplicaciones web utilizadas para publicar "leaks" de información, credenciales y bases de datos tras compromisos de seguridad.

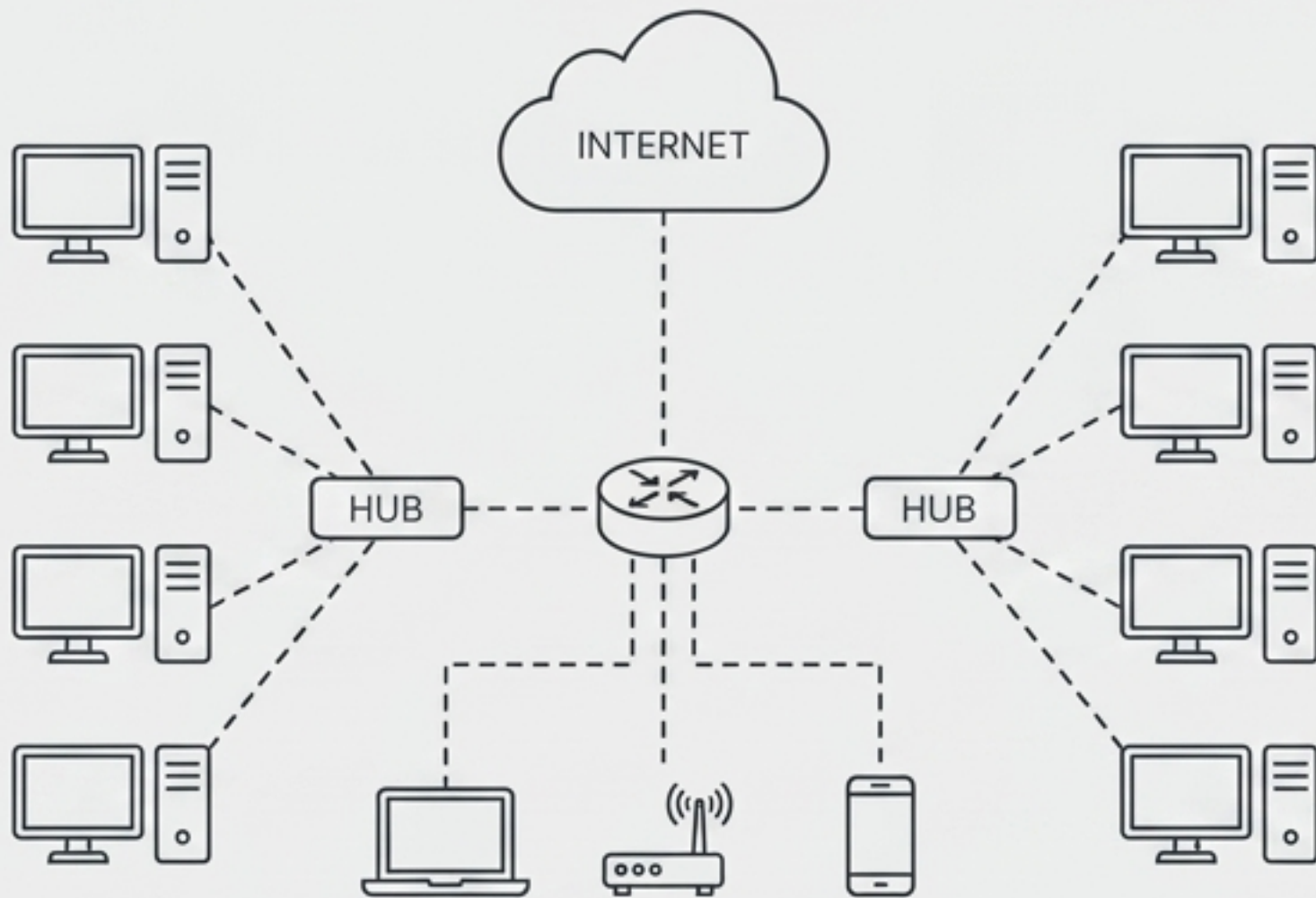
Redes Sociales (RRSS): Permiten obtener organigramas, emails y tecnologías de forma simple. Constituyen el vector principal para preparar Ataques de Ingeniería Social.

Matriz de Reconocimiento OSINT

Herramientas Analizadas	Tipo de Datos Obtenidos	Nivel de Intrusión	Riesgo por Error Humano
Whois / DNS Lookup	Datos de Red e IPs	Baja Intrusión	Riesgo Bajo (Privacidad activa)
Transferencia de Zona	Topología Interna	Media Intrusión	Riesgo Crítico (Mala configuración DNS)
Google Hacking / Robots.txt	Rutas y Archivos Ocultos	Baja Intrusión	Riesgo Alto (Exposición de directorios)
Pastebin / RRSS	Credenciales y Organigramas	Baja Intrusión	Riesgo Crítico (Ingeniería Social / Empleados)

El mapa está trazado. Es hora de interactuar.

El Information Gathering (OSINT) termina exactamente donde empieza la intrusión activa. Ya tenemos el perfil; ahora buscamos la vulnerabilidad técnica.



Siguiente Fase: Escaneos de Red (Nmap)

El proceso pasa a ser mucho más intrusivo. Se identifican hosts activos enviando paquetes directamente a los puertos específicos del objetivo y se analizan las respuestas de los servidores.